

- 
- **GreenLeaf E-Commerce –  
Third-Party Risk  
Management (TPRM) Policy**

- **Cameron Naidoo**

- **Date: 29 June 2026**

- **Version: 1.0**

- **Classification: Confidential**

## 1. Purpose

The purpose of this policy is to establish a standardized framework for identifying, assessing, monitoring, and mitigating risks associated with third-party vendors. GreenLeaf E-Commerce relies on external vendors (e.g., payment processors, cloud providers, marketing agencies) to support critical business operations. A breach or failure at a vendor could result in data loss, financial penalties, and reputational damage. This policy ensures that all vendors meet GreenLeaf's minimum security requirements before engagement and on an ongoing basis.

## 2. Scope

This policy applies to all vendors, subcontractors, and third-party service providers that:

- Access, process, or store GreenLeaf customer data (including PII and payment information).
- Provide critical services that support GreenLeaf's daily operations (e.g., website hosting, payment processing).
- Have the ability to impact GreenLeaf's reputation or legal compliance (e.g., GDPR, PCI DSS).

This policy does not apply to one-time purchases of office supplies or non-critical software where no data sharing occurs.

## 3. Vendor Tiering System

All vendors must be assigned a tier based on their potential impact on GreenLeaf. The tier determines the assessment frequency and the level of due diligence required.

| Tier     | Description                                                                                          | Example Vendors                      | Assessment Frequency     |
|----------|------------------------------------------------------------------------------------------------------|--------------------------------------|--------------------------|
| Critical | Failure or breach would stop the business or cause catastrophic legal/financial damage.              | PaySecure (Payments), AWS (Hosting)  | Annually / Post-Incident |
| High     | Failure would cause significant operational or financial damage, but business could survive briefly. | CRM Provider, Major Marketing Agency | Annually                 |
| Medium   | Access to limited or non-sensitive data; easily replaceable.                                         | Email Marketing Platform             | Every 2 Years            |
| Low      | No access to sensitive data; simple administrative or consumable services.                           | Office Cleaning Company              | Onboarding Only          |

## 4. Vendor Scoring Criteria (Initial Tiering)

Vendors are assigned a tier based on a score across **three criteria** (scored 1–5). The total score determines the tier.

| Criteria         | Scoring Guide                                                                                                        | Weight |
|------------------|----------------------------------------------------------------------------------------------------------------------|--------|
| Data Sensitivity | <b>1:</b> Public data only. <b>3:</b> Internal non-PII data. <b>5:</b> PII / Credit Card Data.                       | High   |
| Business Impact  | <b>1:</b> Interruption for >30 days. <b>3:</b> Interruption for 7-30 days. <b>5:</b> Interruption for <24 hours.     | High   |
| Risk Transfer    | <b>1:</b> No insurance / no liability. <b>3:</b> Standard liability. <b>5:</b> \$5M+ Insurance with indemnification. | Medium |

Tiering Matrix (Total Score):

**12–15:** Critical    **8–11:** High    **4–7:** Medium    **3:** Low

## 5. Vendor Security Questionnaire

Prior to engagement, and on an ongoing basis (based on tier), all vendors must complete the **GreenLeaf Vendor Security Questionnaire**. Evidence (e.g., certificates, policy excerpts) must be provided where indicated.

1. Access Control
  - 1.1 Do you enforce Multi-Factor Authentication (MFA) for all remote and administrative access to your systems?
  - 1.2 Do you require a VPN, Zero Trust Network Access (ZTNA), or equivalent secure encrypted connection for all remote access to your internal networks and systems?
2. Data Protection
  - 2.1 Do you encrypt all customer data (including PII and payment information) at rest using industry-standard encryption (e.g., AES-256)?
  - 2.2 Do you encrypt all customer data in transit using TLS 1.2 or higher (e.g., HTTPS, secure VPN tunnels)?
3. Incident Response
  - 3.1 Do you have a formal, documented Incident Response Plan (IRP) that has been tested within the last 12 months?
  - 3.2 Do you commit to notifying GreenLeaf of any confirmed or suspected security incident or data breach affecting our data within **24 hours** of discovery?
4. Subcontractors
  - 4.1 Do you share, transfer, or otherwise provide access to our data to any subcontractors, third-party service providers, or affiliates?
  - 4.2 Do you conduct security and privacy due diligence on all subcontractors before engagement, and ensure they are bound by contractual obligations (e.g., Data Processing Agreements) that are at least as strict as your own security requirements?
5. Compliance
  - 5.1 Do you hold current ISO 27001:2022 certification? If so, please provide the certificate and the date of your most recent surveillance audit.
  - 5.2 Do you hold current PCI DSS certification? If so, please provide the Attestation of Compliance (AoC) and the date of your most recent assessment.

## 6. Risk Scoring Matrix

Vendor answers are scored using a weighted system. Answers of "Yes" receive the full weight. "No" receives 0 points. "Partial" receives half weight.

Weighted Questions:

- **Weight 5 (Critical):** 1.1 (MFA), 2.1 (Encryption at Rest), 3.1 (IRP), 5.1 (ISO 27001)
- **Weight 4 (High):** 1.2 (VPN/ZTNA), 2.2 (Encryption in Transit), 3.2 (24h Notification), 4.1 (Subcontractor Disclosure)
- **Weight 3 (Medium):** 4.2 (Subcontractor DD), 5.2 (PCI DSS)

Maximum Possible Score: 42 points

| Total Score | Risk Tier | Action Required                                                                |
|-------------|-----------|--------------------------------------------------------------------------------|
| 35–42       | Low       | Accept. Monitor annually.                                                      |
| 25–34       | Medium    | Mitigate. Request remediation plan. Monitor quarterly.                         |
| 15–24       | High      | Mitigate with strict contract clauses. Restrict data sharing. Monitor monthly. |
| 0–14        | Critical  | Avoid immediately. Find a new vendor.                                          |

### **Risk Override Rule:**

If a vendor scores **0** on any **two** of the Weight 5 Critical questions (1.1 MFA, 3.1 IRP, 5.1 ISO 27001), they shall be automatically escalated to **Critical Risk**, regardless of the total score.

## 7. Mandatory Contractual Requirements (Security Clause)

The following clause shall be included in all contracts with Critical or High-Risk vendors:

*"The Vendor shall maintain and enforce commercially reasonable security measures, including but not limited to: Multi-Factor Authentication (MFA) for all administrative access, encryption of Customer Data at rest (AES-256) and in transit (TLS 1.2 or higher), and a formal, documented Incident Response Plan that has been tested within the preceding twelve (12) months. The Vendor shall notify GreenLeaf in writing of any confirmed or suspected security incident, data breach, or unauthorized access to Customer Data within twenty-four (24) hours of discovery. GreenLeaf, or its designated third-party representative, shall have the right to conduct a security audit of the Vendor's systems, controls, and processes related to the protection of Customer Data upon reasonable notice (not less than thirty (30) days), limited to no more than once per calendar year unless a security incident has occurred."*

## **8. Review Cycle**

This TPRM Policy shall be reviewed annually or immediately following a major vendor security incident. Updates must be approved by the CEO and CTO.